

ЛЕКЦИЯ 6

**Управление на идентичностите и
достъпа (Identity and Access
Management)**

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за приложение на RBAC

(a) Functions and Official Positions

Role	Function	Official Position
A	financial analyst	Clerk
B	financial analyst	Group Manager
C	financial analyst	Head of Division
D	financial analyst	Junior
E	financial analyst	Senior
F	financial analyst	Specialist
G	financial analyst	Assistant
...	...	...
X	share technician	Clerk
Y	support e-commerce	Junior
Z	office banking	Head of Division

- Дрезднер банк преминава от DAC към RBAC решение

(b) Permission Assignments

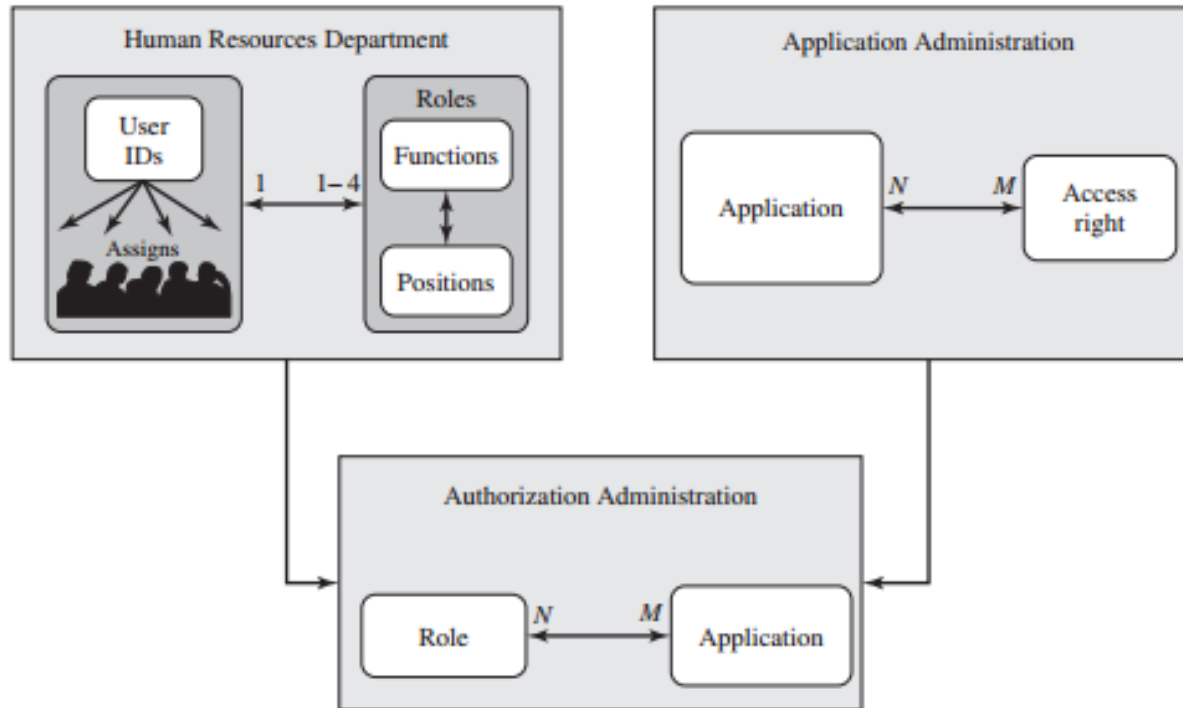
Role	Application	Access Right
A	money market instruments	1, 2, 3, 4
	derivatives trading	1, 2, 3, 7, 10, 12
	interest instruments	1, 4, 8, 12, 14, 16
B	money market instruments	1, 2, 3, 4, 7
	derivatives trading	1, 2, 3, 7, 10, 12, 14
	interest instruments	1, 4, 8, 12, 14, 16
	private consumer instruments	1, 2, 4, 7
...	...	...

(c) Permission Assignment with Inheritance

Role	Application	Access Right
A	money market instruments	1, 2, 3, 4
	derivatives trading	1, 2, 3, 7, 10, 12
	interest instruments	1, 4, 8, 12, 14, 16
B	money market instruments	7
	derivatives trading	14
	private consumer instruments	1, 2, 4, 7
...	...	...

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за приложение на RBAC



- 65 позиции
- 368 работни функции
- 1300 роли вместо $65 \times 368 = 23920$ потенциални роли
- Средно дневно, 42000 секюрити профила се разпределят към приложенията

доц. д-р инж. Росен Радков

Контрол на достъп базиран на атрибути (ABAC)

- Модел за контрол на достъп, който дефинира оторизациите (разрешенията), на базата на свойствата както на ресурса така и на субекта;

Пример: Ако се разгледа конфигурация, в която всеки ресурс има атрибут, идентифициращ субекта, който е създал ресурса. Тогава с едно правило би могло да се определи привилегията „собственик на ресурс“, която да бъде присвоена на всички, които са създали ресурс.

МРЕЖОВО АДМИНИСТРИРАНЕ

- Този подход притежава изключителна гъвкавост и мощ, защото дава възможност решенията за предоставяне на достъп да се вземат на базата на много характеристики;
- Като недостатък и донякъде пречка за широкото му разпространение се изтъква влиянието върху **производителността** при оценката на правилата свързани с характеристиките на потребителите и ресурсите за осъществяването на всеки достъп.

МРЕЖОВО АДМИНИСТРИРАНЕ

- Пионери в използването на този метод са уеб услугите, особено чрез въвеждане на *eXtensible Access Control Markup Language (XACML)*;
- Елементи на АВАС модела са:
 - Атрибути – които са дефинирани за единиците в дадена конфигурация;
 - Модел на политиката – определящ политиките на АВАС;
 - Модел на архитектурата – който прилага политиките, чрез които се осъществява контрола на достъп;

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ **Атрибути** - характеристики, които определят специфични аспекти на **субекта, обекта, условията на заобикалящата среда** и / или **заявените операции**, които предварително са определени и назначени от даден орган. Всеки атрибут съдържа данни за:

- клас на информацията;
- име;
- стойност;

Пример:

Class=HospitalRecordsAccess

Name=PatientInformationAccess

Value=MFBusinessHoursOnly

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

◆ Видове атрибути

- *Атрибути на субектите*

Субектът може да бъде user, application, process, device, т.е. той е активна единица, която е причина за поток от информация между обектите или промени в състоянието на системата. Атрибутите са асоциирани със субекта и определят неговата самоличност и характеристики (идентификатор на субекта, име, име на организацията, длъжност, роля и др.);

МРЕЖОВО АДМИНИСТРИРАНЕ

◆ Видове атрибути

● *Атрибути на обектите*

Обектът, наричан още ресурс, е пасивна (в контекста на дадената заявка) свързана с информационната система единица (например устройства, файлове, записи, таблици, процеси, програми, мрежи, домейни), съдържащ или получаващ информация. Той притежава характеристики, които могат да бъдат използвани, за вземане на решение за достъп до него.

Например, един документ .doc има характеристики: име, заглавие, дата и автор. Често атрибутите могат да бъдат извлечени от метаданните на обектите. В частност, разнообразни атрибути на метаданни на уеб услуги могат да бъдат от значение за целите на контрола на достъпа, като например собственост, таксономия на услугата или дори атрибути за качество на услугата (QoS).

МРЕЖОВО АДМИНИСТРИРАНЕ

◆ Видове атрибути

- *Атрибути на заобикалящата среда* - описват оперативната, техническата и дори ситуационната среда или контекст, в които се осъществява достъпът до информацията, например: текуща дата и час; вирусните и хакерски атаки в съответния момент; нивото на защита на мрежата (Интернет/Интранет), мястото откъдето се осъществява достъпа и др. ;

Атрибутите на заобикалящата среда не са свързани с конкретен субект или ресурс, но могат да бъдат подходящи за прилагане на политика за контрол на достъпа.

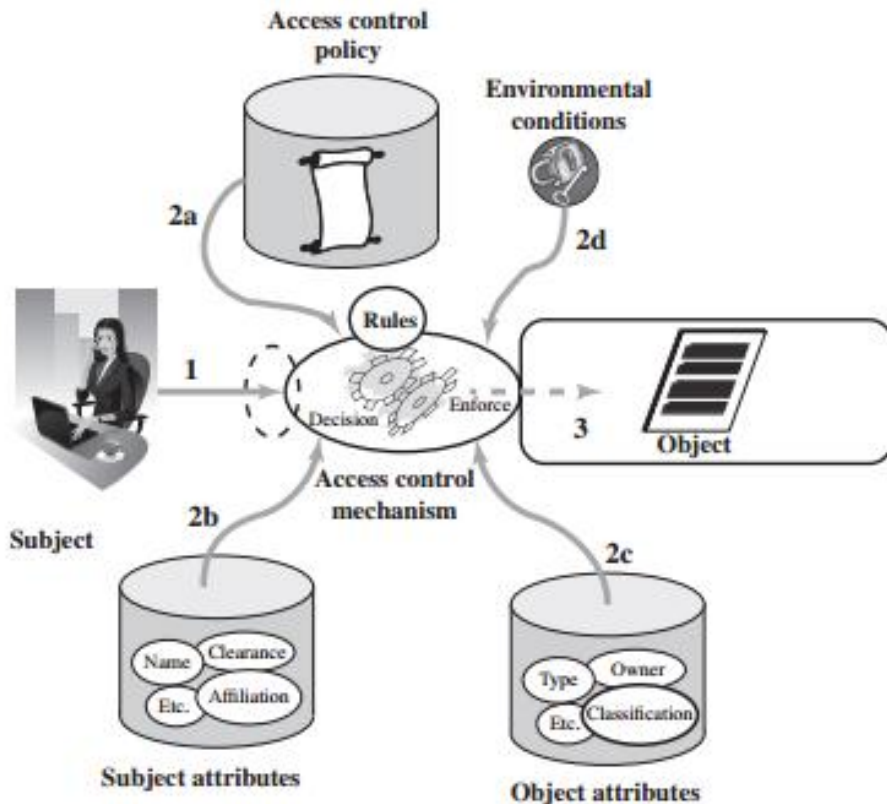
МРЕЖОВО АДМИНИСТРИРАНЕ

Обобщени характеристики на АВАС

- логически модел за контрол на достъп, който управлява достъпа, оценявайки правилата спрямо атрибутите на субектите и обектите, операциите и заобикалящата среда, съответстваща на заявката;
- разчита на оценката на атрибутите на субекта, атрибутите на обекта и формалната връзка или правило за контрол на достъпа, определящо допустимите операции за комбинации от атрибути subject-object в дадена среда;
- АВАС са в състояние да наложат концепции за DAC, RBAC и MAC;
- АВАС позволява неограничен брой атрибути да бъдат комбинирани, за да отговарят на всяко правило за контрол на достъпа;

МРЕЖОВО АДМИНИСТРИРАНЕ

Логическа архитектура на АВАС



1. Субектът подава заявка за достъп до обект

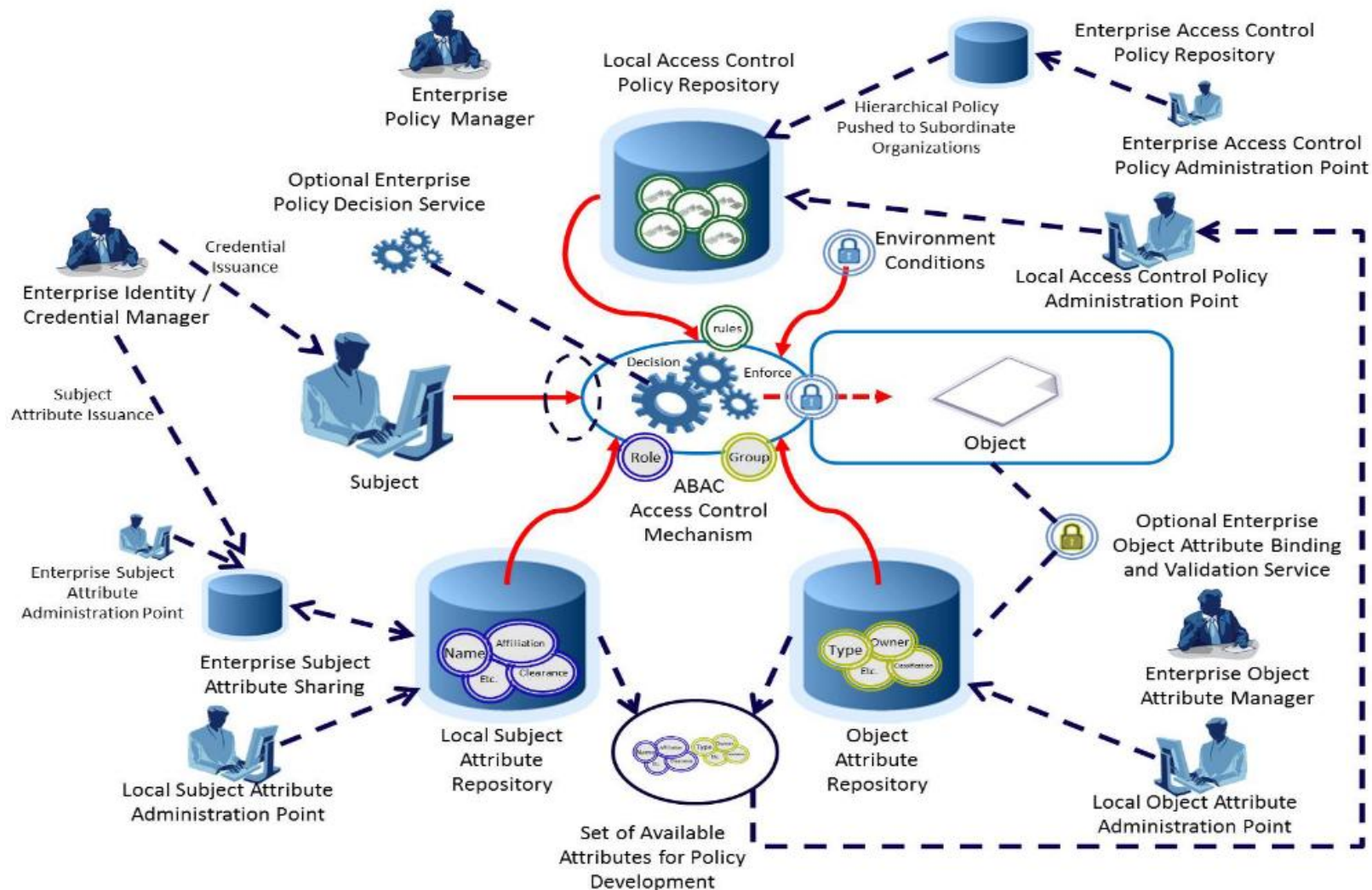
2. Механизмът на контрола на достъп се управлява от правила 2a, които са предварително конфигурирани в политиката за контрол на достъп. На базата на тези правила и оценката на атрибутите на субекта (2b), обекта (2c) и на заобикалящата среда (2d), се определя оторизацията

3. Механизмът на контрола на достъп „Предоставя/Не предоставя“ достъп до обекта

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

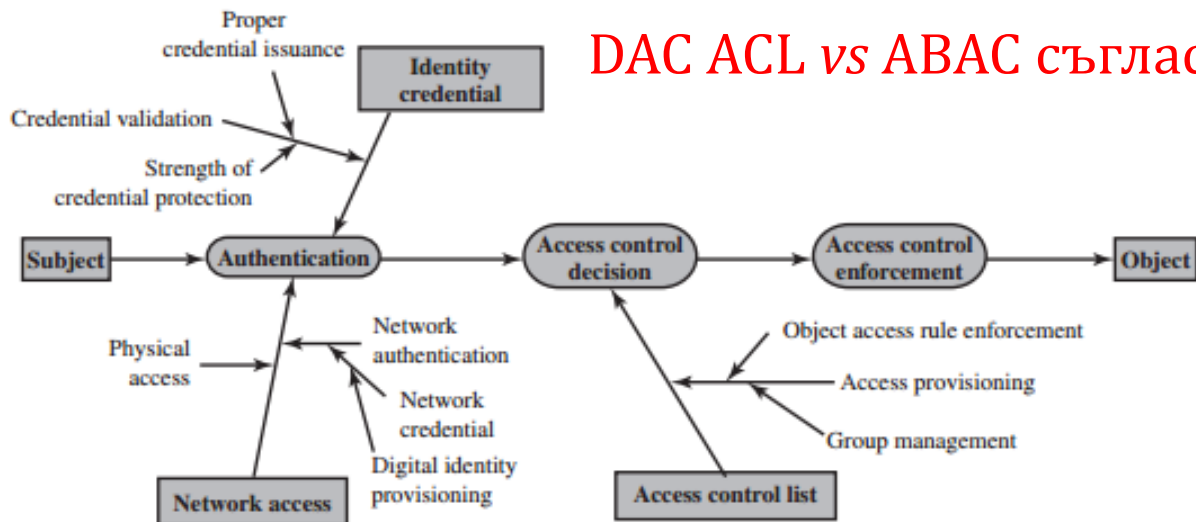
Пример за АВАС архитектура



доц. д-р инж. Росен Радков

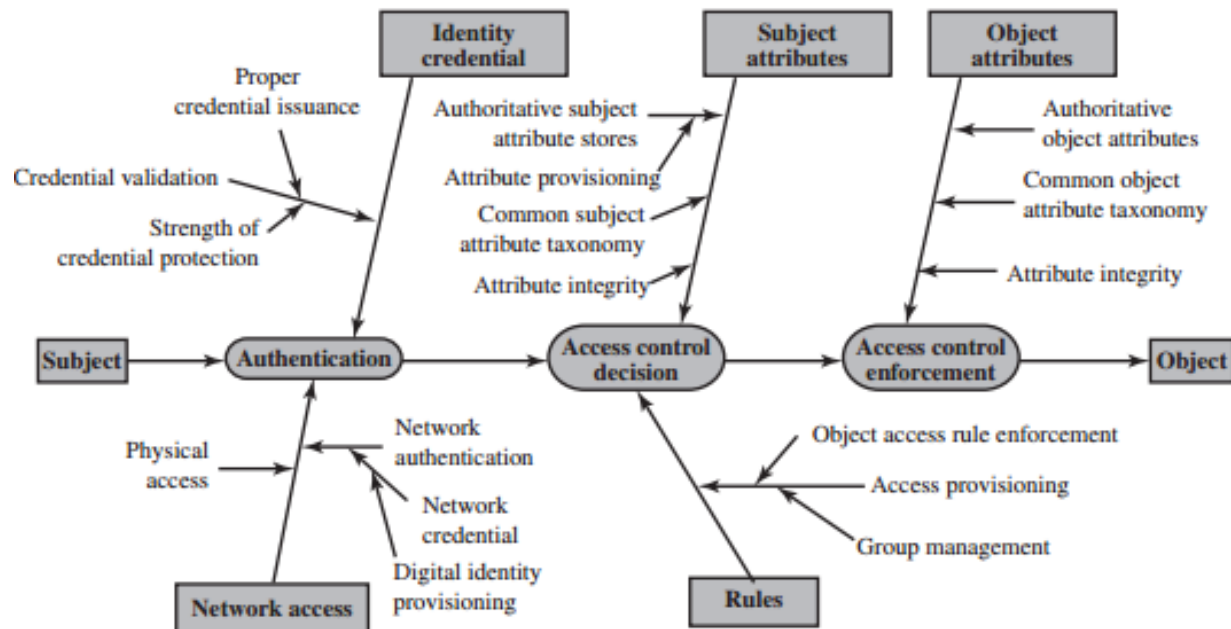
МРЕЖОВО АДМИНИСТРИРАНЕ

ДАС ACL vs ABAC съгласно NIST SP 800-162



Доверителна
верига при ACL –
корен на доверието
е собственика на
обекта

Доверителна
верига при ABAC –
корен на доверието
се извлича от
много източници,
върху които
собственика на
обекта няма
контрол



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

- Препоръчва се да се създаде **корпоративен орган за управление** на възможностите за внедряване и функциониране на *identity, credential* и *access management*, както в дадена организация така и всяка подчинена на нея да поддържа подобен орган, за да се осигури последователност в управлението на разгръщането и промяната на корпоративната АВАС;
- Препоръчва се да бъде разработен **модел на доверие**, който да бъде използван за илюстриране на доверителните отношения и за определяне на собствеността и отговорността на информацията и услугите, нуждите от допълнителни политики и управление, както и изисквания към техническите решения използвани за валидиране или прилагане на доверителните отношения;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

- **Моделът за доверие** може да се използва, за да се помогне на организациите да споделят своята информация с ясните очаквания за това как тази информация ще бъде използвана и защитена. Освен това той осигурява възможност да се придобие доверие за информацията, атрибутите и разрешенията, идващи от други организации.

МРЕЖОВО АДМИНИСТРИРАНЕ

Политики на АВАС

- Политиките са набор от правила и взаимоотношения, които регулират допустимото поведение в рамките на дадена организация, въз основа на привилегиите на субектите и как трябва да бъдат защитени ресурсите (обектите) и при какви условия на заобикалящата среда.

Могат да се използват следните правила:

1. Дефинират се S (субекти), O (обекти) и E (заобикаляща среда)
2. SA_k ($1 \leq k \leq K$), OA_m ($1 \leq m \leq M$), и EA_n ($1 \leq n \leq N$) са техните предварително дефинирани атрибути

МРЕЖОВО АДМИНИСТРИРАНЕ

Политики на АВАС

3. $ATTR(s)$, $ATTR(o)$, и $ATTR(e)$ са отношения за присвояване на атрибути:

$$ATTR(s) \subseteq SA_1 \times SA_2 \times \dots \times SA_K$$

$$ATTR(r) \subseteq OA_1 \times OA_2 \times \dots \times OA_M$$

$$ATTR(o) \subseteq EA_1 \times EA_2 \times \dots \times EA_N$$

Например:

$Role(s) = \text{"Service Consumer"}$

$ServiceOwner(o) = \text{"XYZ, Inc."}$

$CurrentDate(e) = \text{"16-11-2022"}$

МРЕЖОВО АДМИНИСТРИРАНЕ

Политики на АВАС

4. Обща форма на правило, което определя достъп на субект s , до обект o при условията на заобикалящата среда e :

$$\text{Rule: can_access}(s, o, e) \leftarrow f(\text{ATTR}(s), \text{ATTR}(o), \text{ATTR}(e))$$

5. Базата с правила на политиката (хранилището на правилата) може да се състои от множество правила, обхващащи много субекти и обекти в рамките на домейна за сигурност. Процесът на вземане на решение, за контрол на достъпа по същество, се състои в оценка на приложимите правила от политиката на АВАС.

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение за прилагане на RVAC и AVAC политики (1)

Пример: онлайн магазин за развлечения, който излъчва филми към потребителите, срещу фиксирана месечна такса. Магазинът трябва да прилага следната политика за контрол на достъпа въз основа на възрастта на потребителя и оценката на съдържанието на филма:

Рейтинг на филмите	Потребители, за които са предназначени
R	Мин на 17 години
PG-13	Мин на 13 години
G	ВСИЧКИ

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение за прилагане на RBAC и ABAC политики (2)

При прилагане на RBAC, на всеки потребител ще бъде присвоена една от трите роли: **Възрастен**, **Непълнолетен** или **Дете**, възможно още по време на регистрацията. Ще бъдат създадени три разрешения: „Може да гледа филми с R-рейтинг“, „Може да гледа филми с рейтинг PG-13“ и „Може да гледа филми, които са с рейтинг G“. За ролята **Възрастен** се назначават трите разреше-ния; за ролята **Непълнолетен** - „Може да гледа филми с рейтинг PG-13“ и „Може да гледа филми, които са с рейтинг G“; а ролята **Дете** получава само разрешение „Може да гледа филми, които са с рейтинг G“. Присвояването на потребител към роля и присвояването на разрешение към роля са ръчно извършвани административни задачи.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение за прилагане на RBAC и ABAC политики (3)

Прилагане на ABAC:

R1:can_access(u, m, e) $\leftarrow$
 $(\text{Age}(u) \geq 17 \wedge \text{Rating}(m) \in \{R, PG-13, G\}) \vee$
 $(\text{Age}(u) \geq 13 \wedge \text{Age}(u) < 17 \wedge \text{Rating}(m) \in \{PG-13, G\}) \vee$
 $(\text{Age}(u) < 13 \wedge \text{Rating}(m) \in \{G\})$

Където:

u – субект

$Age, Rating$ - атрибути

m – обект (филм)

e – заобикалящата среда

Предимство: (1) елиминира се дефинирането и управлението на статичните роли; (2) по този начин се елиминира нуждата от изпълнение на административни задачи за задаване на отношения **потребител-към-роля** и за **разрешение-към-роля**.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение за прилагане на RBAC и ABAC политики (4)

Предимството на ABAC се вижда по-ясно, когато се налагат по-фини политики. Да предположим например, че филмите са класифицирани като "*New Release*" или "*Old Release*", според датата им на пускане в сравнение с текущата дата, а потребителите се класифицират като *Premium User* и *Regular User* въз основа на таксата, която плащат. Ако се изисква да се приложи политика, при която само *Premium User* да могат да гледат нови филми, то:

- за модела RBAC ще трябва да се удвои броя на ролите, за да се различи всеки потребител по възраст и такса, и ще трябва да се удвои и броя на отделните разрешения. Като цяло, ако има K атрибути на субекта и M атрибути на обекта и ако за всеки атрибут $Range()$ обозначава

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение за прилагане на RBAC и ABAC политики (5)

диапазона на възможните стойности, които могат да бъдат взети, съответният брой роли и разрешения, необходими за RBAC модела, са:

$$\prod_{k=1}^K \text{Range}(SA_k) \quad \text{and} \quad \prod_{m=1}^M \text{Range}(SA_m)$$

т.е. с увеличаване на броя на атрибутите, за да се съобразят с по-фините правила, броят на ролите и разрешенията нараства експоненциално.

При модела ABAC, добавянето на допълнителни атрибути става по много по-ефективен начин. Към политиката R1, определена по-рано, трябва да се добавят две нови правила:

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение за прилагане на RBAC и ABAC политики (6)

$R2: \text{can_access}(u, m, e) \leftarrow$
 $(\text{MembershipType}(u) = \text{Premium})$
 $(\text{MembershipType}(u) = \text{Regular} \wedge \text{MovieType}(m) = \text{OldRelease})$
 $R3: \text{can_access}(u, m, e) \leftarrow R1 \wedge R2$

С модела ABAC е лесно да се добавят атрибути на заобикалящата среда. Ако искаме да добавим ново правило в политиката, изразено с думи, както следва:

„Редовните потребители имат право да виждат нови издания в промоционални периоди“.

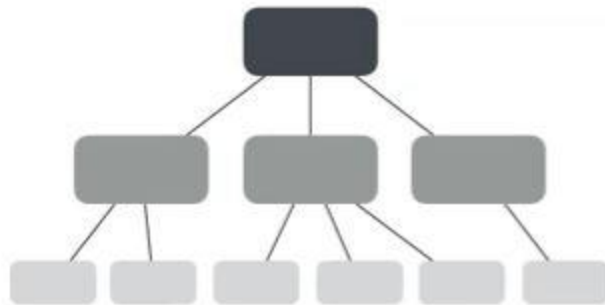
Това би било трудно да се изрази в модела на RBAC.

В модела ABAC, трябва само да добавим конюнктивно (AND) правило, което да провери атрибута на заобикалящата среда **„днешна дата“** дали попада в промоционален период.

МРЕЖОВО АДМИНИСТРИРАНЕ

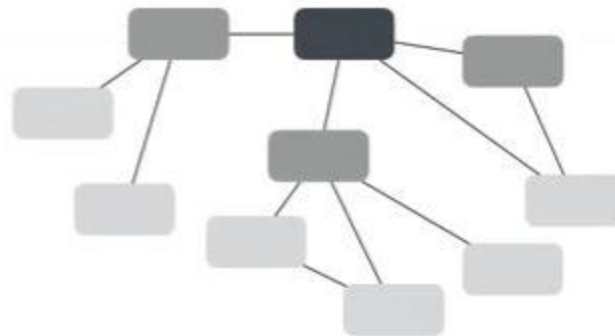
Къде има място моделът АВАС?

Ideal World



Parent-Child relationships

Real World



Query complex relationships in real-time

Identity, Credential and Access Management (ICAM)

„Управлението на идентичността е набор от бизнес процеси и поддържаща инфраструктура за създаване, поддръжка и използване на цифрови идентичности.“

Burton Group (изследователска фирма, специализирана в областта на ИТ инфраструктурата на предприятието)

Identity, Credential and Access Management (ICAM)

Според Gartner, Inc. IAM е:

“Identity and access management is a security, risk management, and business discipline that ensures the right individuals have the right access to the right resources at the right time for the right reasons.”

Identity & Access Management (IAM)

Who gets access to what, at the right time,
and for the right reason

Identity, Credential and Access Management (ICAM)

Т.е. ICAM е цялостен подход към управлението и внедряването на цифрови идентичности (и свързаните с тях атрибути), идентификационни данни и контрол на достъпа.

ICAM е разработен от правителството на САЩ, но е приложим не само за правителствени агенции, а може да бъде използван от предприятия, търсещи единен подход за контрол на достъпа.

Identity, Credential and Access Management (ICAM)

КОЙ СИ ТИ?

- име
- изображение
- идентификатори
- информация за контакт
- адрес, местоположение
- биографична скица, слоган
- принадлежности (националност, групи, принадлежности, демографски данни)
- други показатели за идентичност (биометрични данни)
- предпочитания за поверителност и споделяне на данни
- интереси, намерения
- дейности, отговорности, проекти
- репутация

Identity, Credential and Access Management (ICAM)

WHAT YOU CAN DO?

- authority
- delegation
- roles
- groups
- permissions
- entitlements
- limits, constraints
- as they relate to access to resources

Identity, Credential and Access Management (ICAM)

IDENTITY & ACCESS MANAGEMENT

Повече от акроним

- Набор от свързани процеси
- Набор от свързани услуги
- Подпомага за решаване на сложни проблеми
- Начин за предоставяне на стойност на клиентите

IAM е средство за предоставяне на възможности на клиентите, като им помага да управляват своите потребители (кои са те, какво могат да правят) без да имат тежестта да управляват свързаните с процеса ИТ услуги.

МРЕЖОВО АДМИНИСТРИРАНЕ

Identity, Credential and Access management

ICAM е предназначен за:

- Създаване на доверени цифрови идентификатори на физически лица и съответни документи на ICAM, които се отнасят за единици, които не са личности (nonperson entities NPEs). NPE включват процеси, приложения и автоматизирани устройства, които търсят достъп до ресурси.
- Свързване на тези идентификатори с удостоверенията за самоличност, които могат да служат като пълномощник (проху) за физическото лице или NPE в транзакциите за достъп.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Управление на самоличност (идентичност) (Identity management)

- Присвояване на атрибути към цифровата идентичност и свързване на тази **цифрова идентичност** с дадено лице или NPE с цел да се създаде надеждна цифрова идентичност, която да е **независима от конкретно приложение или контекст**;
- Записите за фирмена идентичност не са свързани с наименование на длъжността, длъжностните задължения, местонахождение или необходимост от достъп до определена система. Решенията за контрол на достъпа ще се основават на контекста и съответните атрибути на потребителя, а не само на тяхната идентичност;

МРЕЖОВО АДМИНИСТРИРАНЕ

Управление на идентичности (Identity management)

- Корпоративната концепция за идентичност предполага, че физическите лица ще имат една единствена цифрова идентичност, която може да се използва в отделите и агенциите за множество цели, включително контрол на достъпа.

МРЕЖОВО АДМИНИСТРИРАНЕ

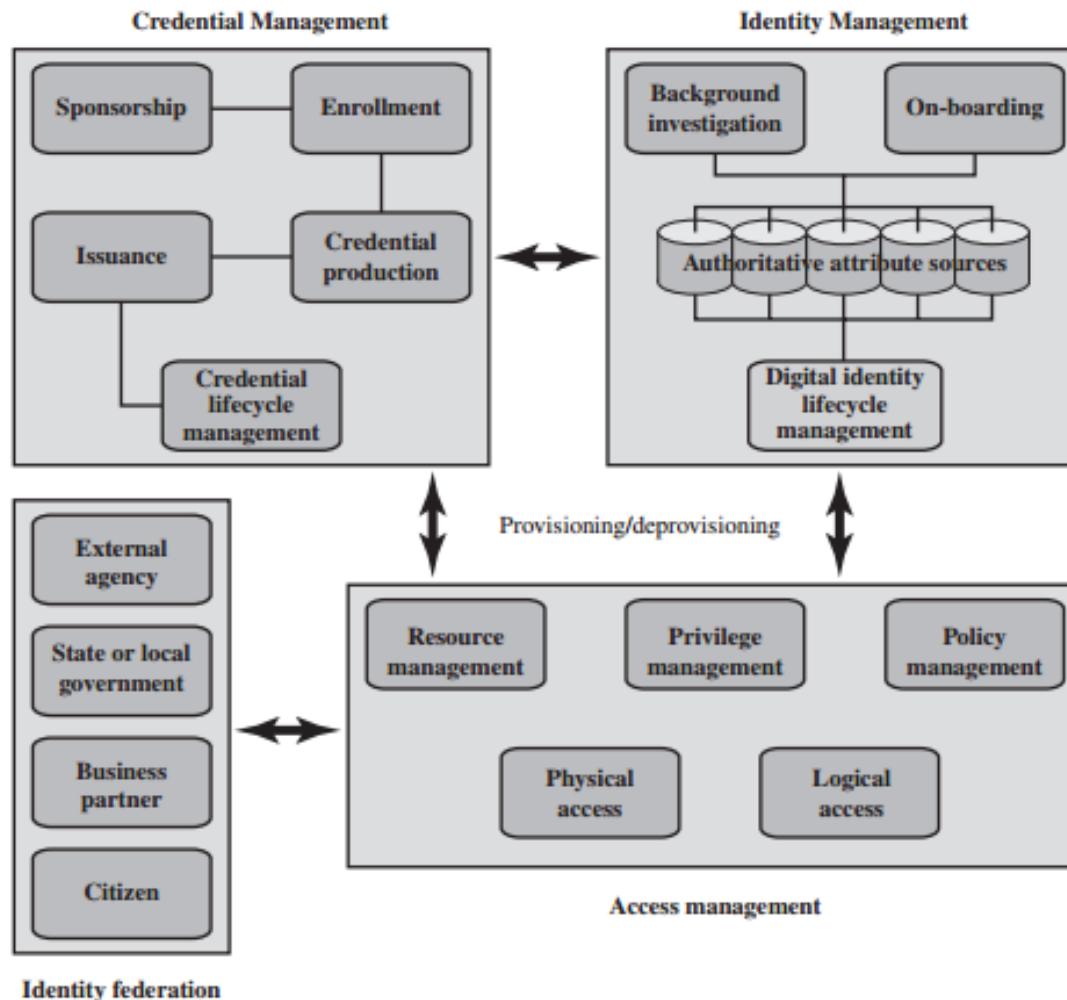
ICAM

Credential Management

Идентификацията (credential) е структура на обект или данни, която авторитетно свързва идентичност (и по желание допълнителни атрибути) с токен, притежаван и управляван от субекта (абонат).

Примери за идентификационни данни са смарт карти, частни / публични криптографски ключове и цифрови сертификати.

Те се управляват през целия техен жизнен цикъл.



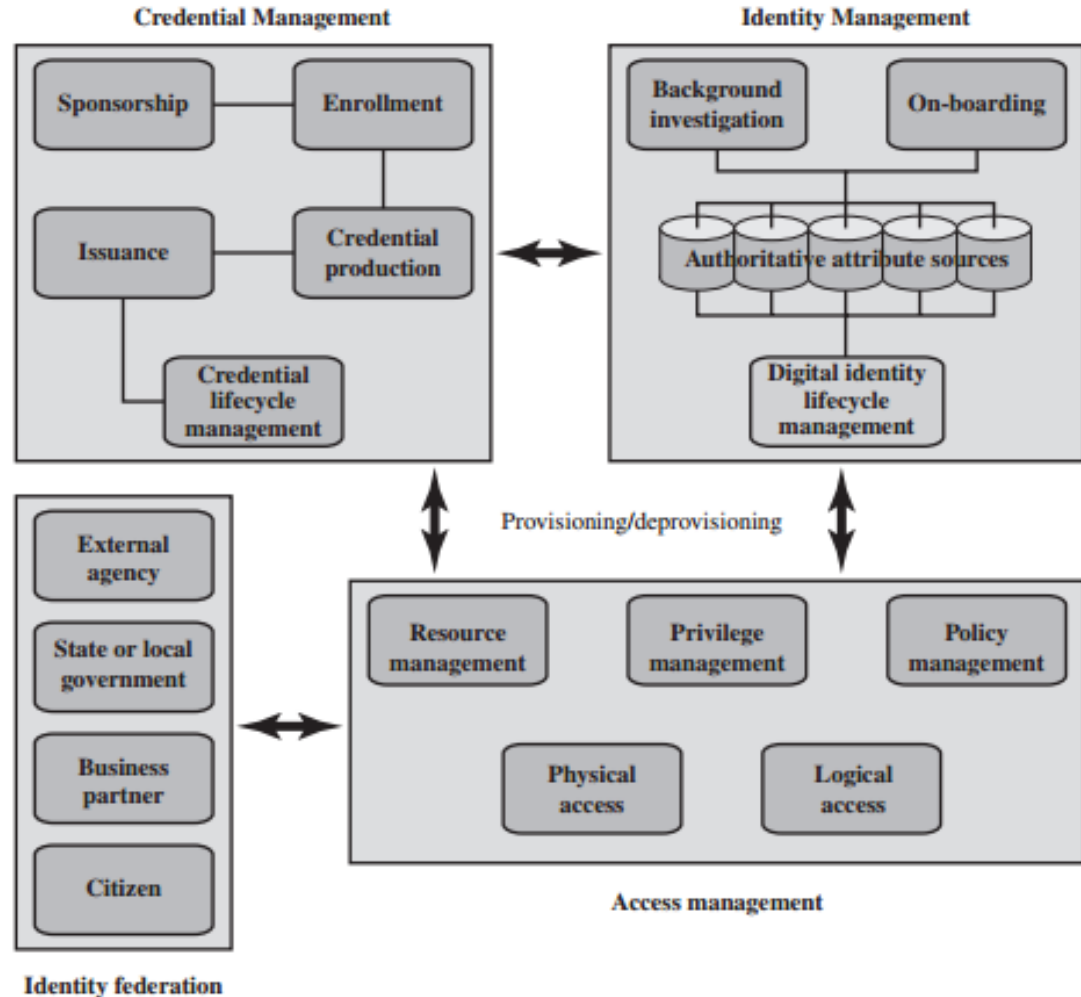
МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Credential Management

Управлението на данните за идентификация обхваща следните пет логически компонента:

1. Упълномощено лице провокира необходимостта от идентификация у физическо или юридическо лице. Например, ръководител на отдела --> служител от отдела.



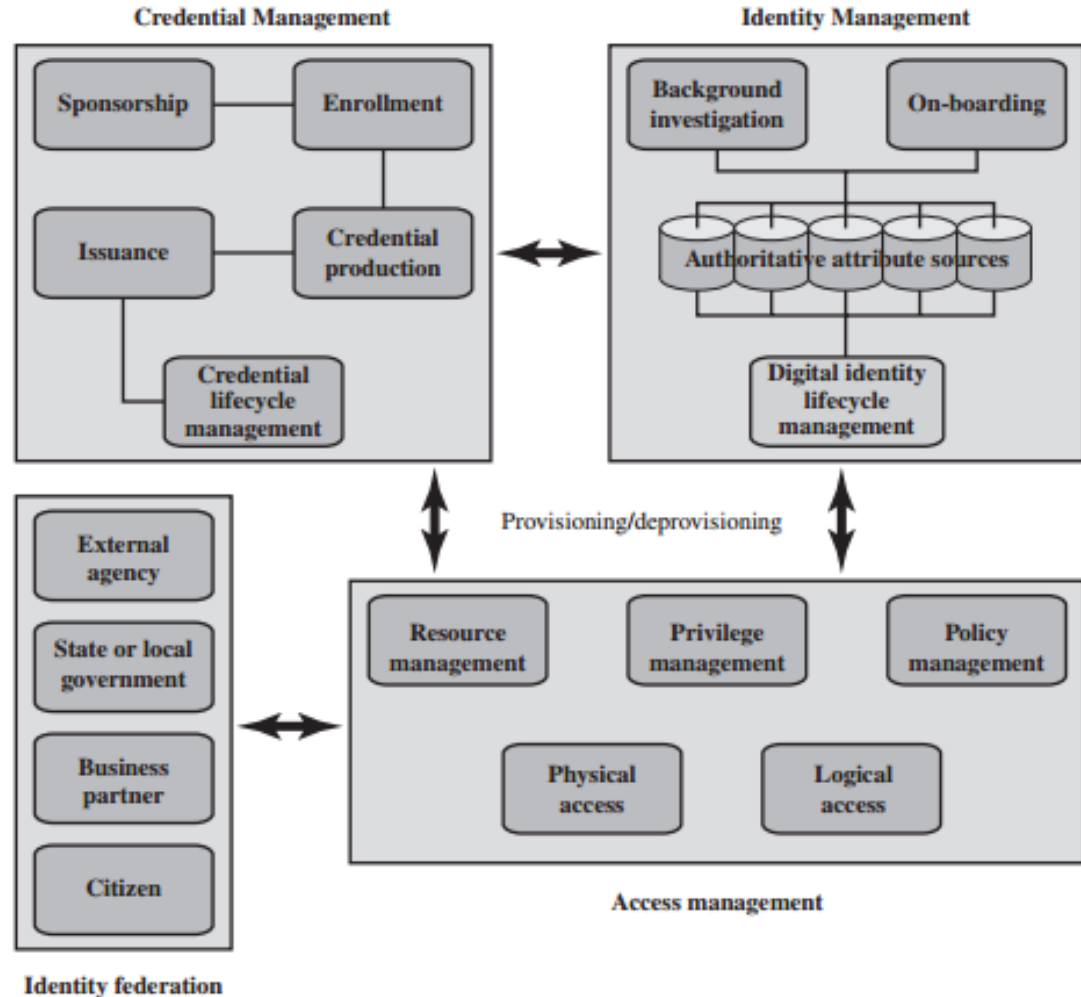
МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Credential Management

2. Съответният индивид се записва за акредитацията, процес, който обикновено се състои от проверка на самоличността и улавяне на биографски и биометрични данни. Тази стъпка може също така да включва използване на данни за атрибути, поддържани от компонента за управление на идентичността.

3. Създава се удостоверение. В зависимост от типа на акредитацията то може да включва шифроване, използване на цифров подпис, производство на карти или други функции.



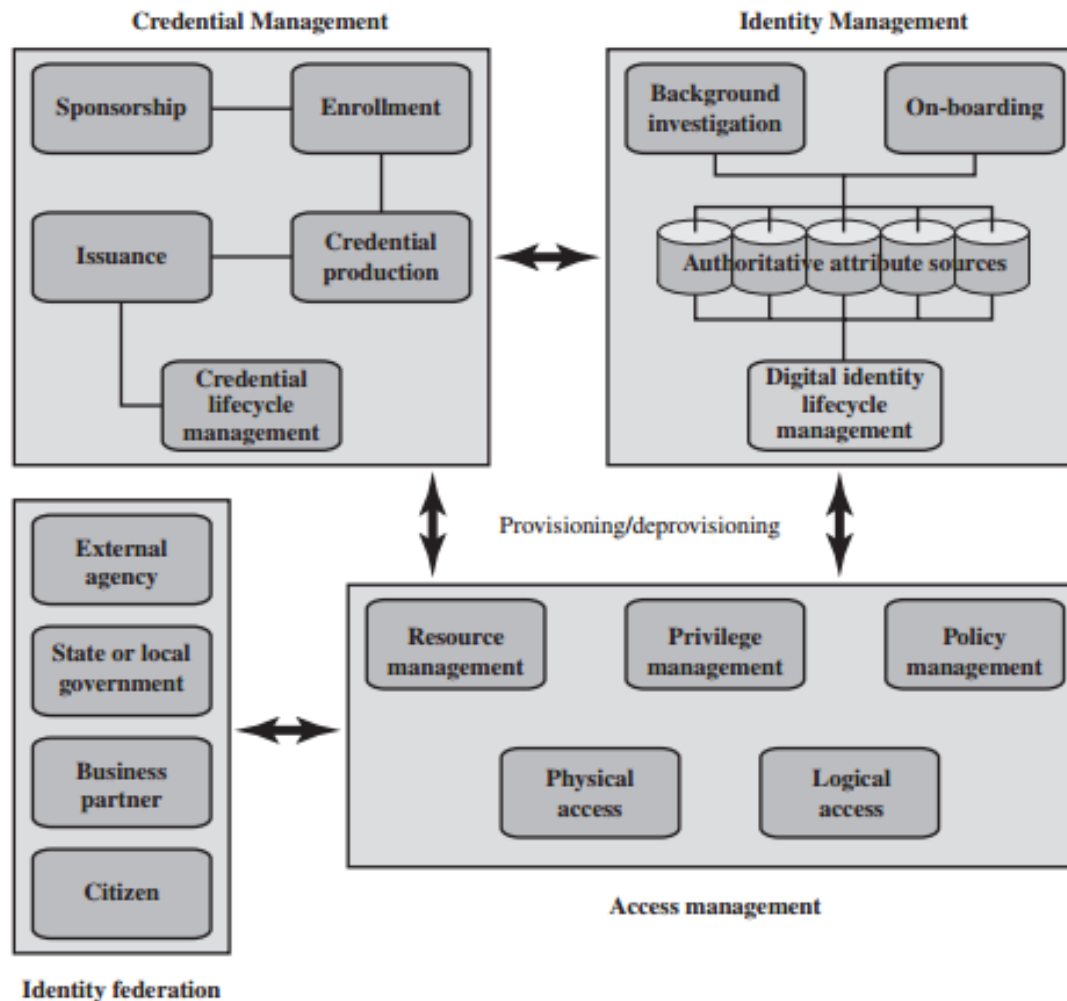
доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Credential Management

4. Лицензията се издава на физическото лице или на НПЕ.
5. Сертификатът трябва да се поддържа през неговия жизнен цикъл, който може да включва отмяна, преиздаване / замяна, повторно записване, изтичане на срока на валидност, нулиране на персоналния идентификационен номер (ПИН), спиране или възстановяване.

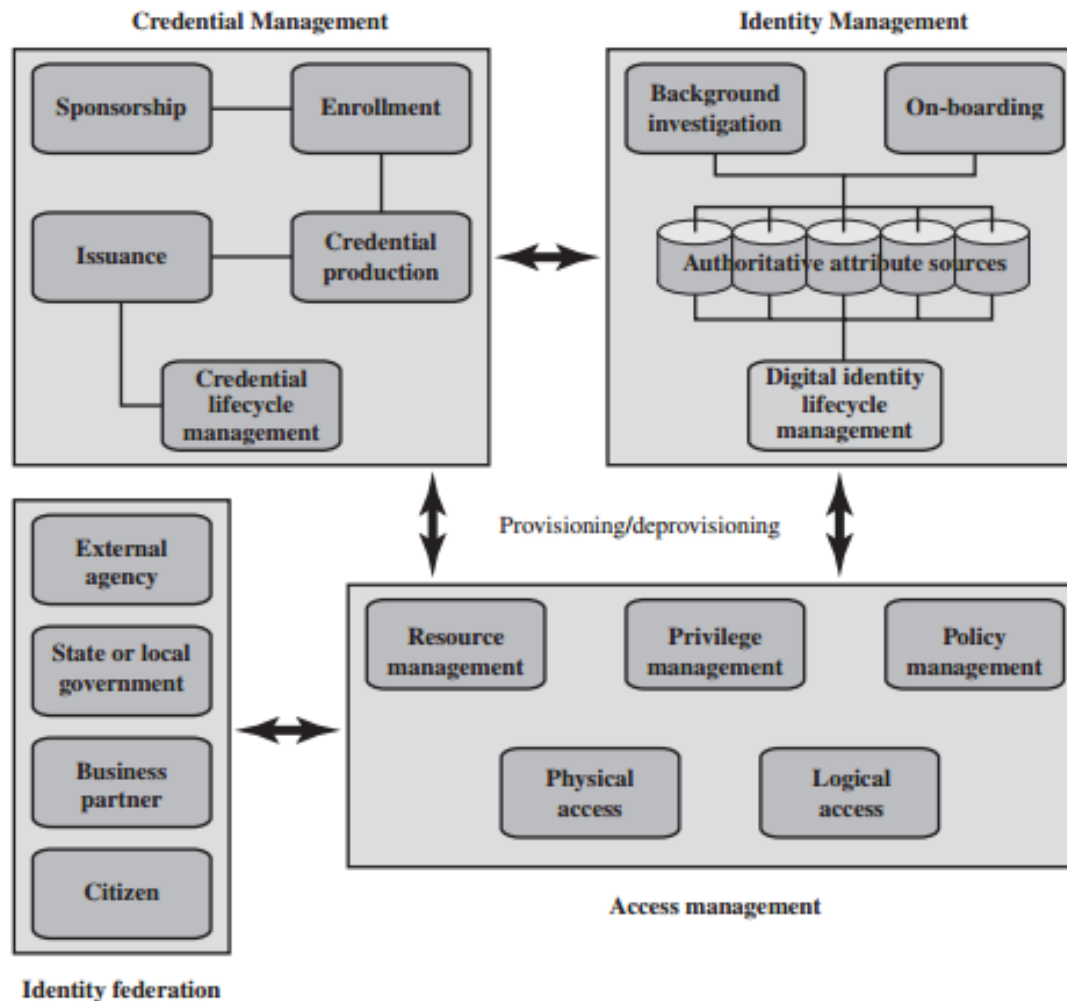


МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Identity management

- Създаването на цифрова идентичност обикновено започва с събирането на данни за самоличност като част от процеса на включване в работния процес.
- Цифровата идентичност често се състои от набор от атрибути, които при агрегиране идентифицират уникално потребителя в рамките на система или предприятие.
- За да се установи доверие в индивида, представявано от цифрова идентичност, дадена агенция може също така да проведе разследване.



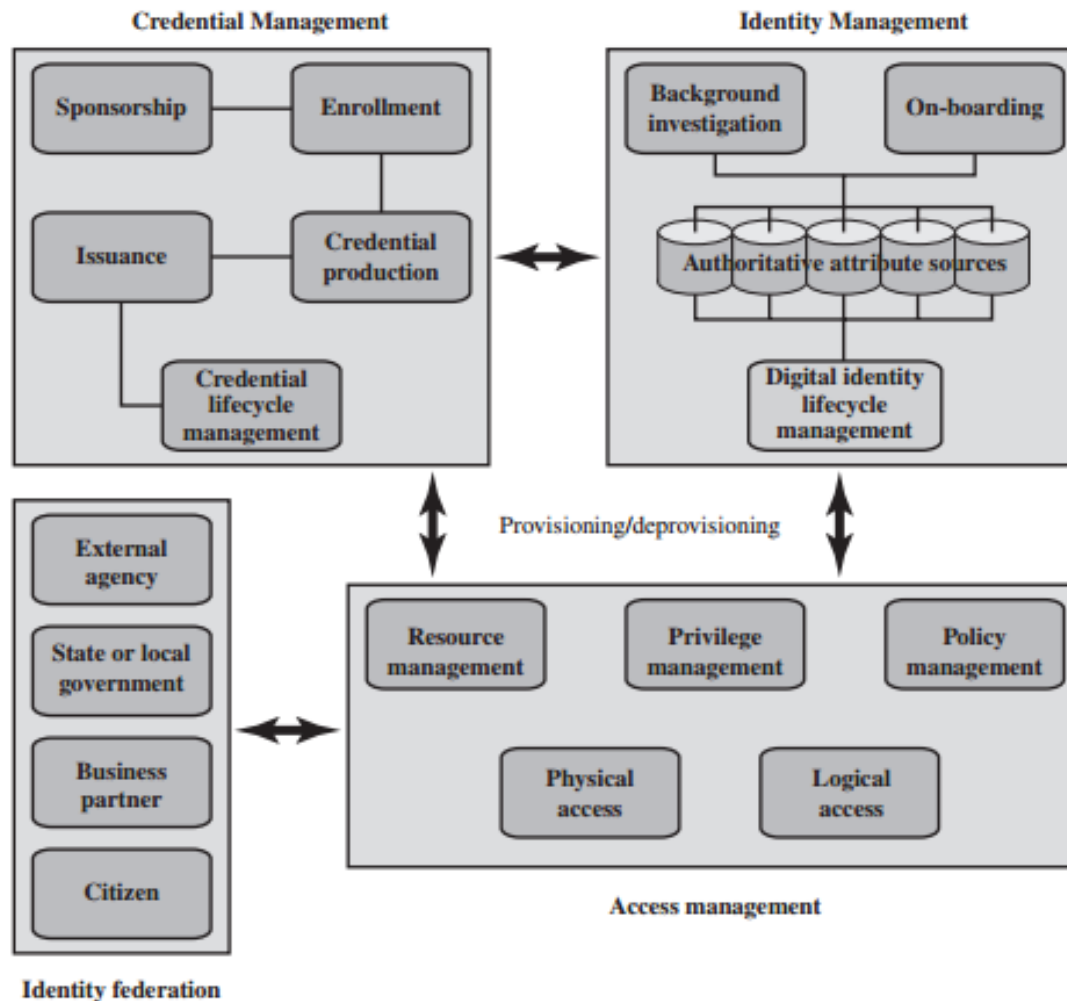
доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Identity management

- Атрибутите за дадено лице могат да се съхраняват в различни авторитетни източници в рамките на една агенция и да са свързани, за да формират фирмен изглед на цифровата идентичност.
- Тази цифрова идентичност може да бъде предоставена в приложения, за да се поддържа физически и логически достъп (част от управлението на достъпа) и той да се деактивира, когато достъпът вече не се изисква.

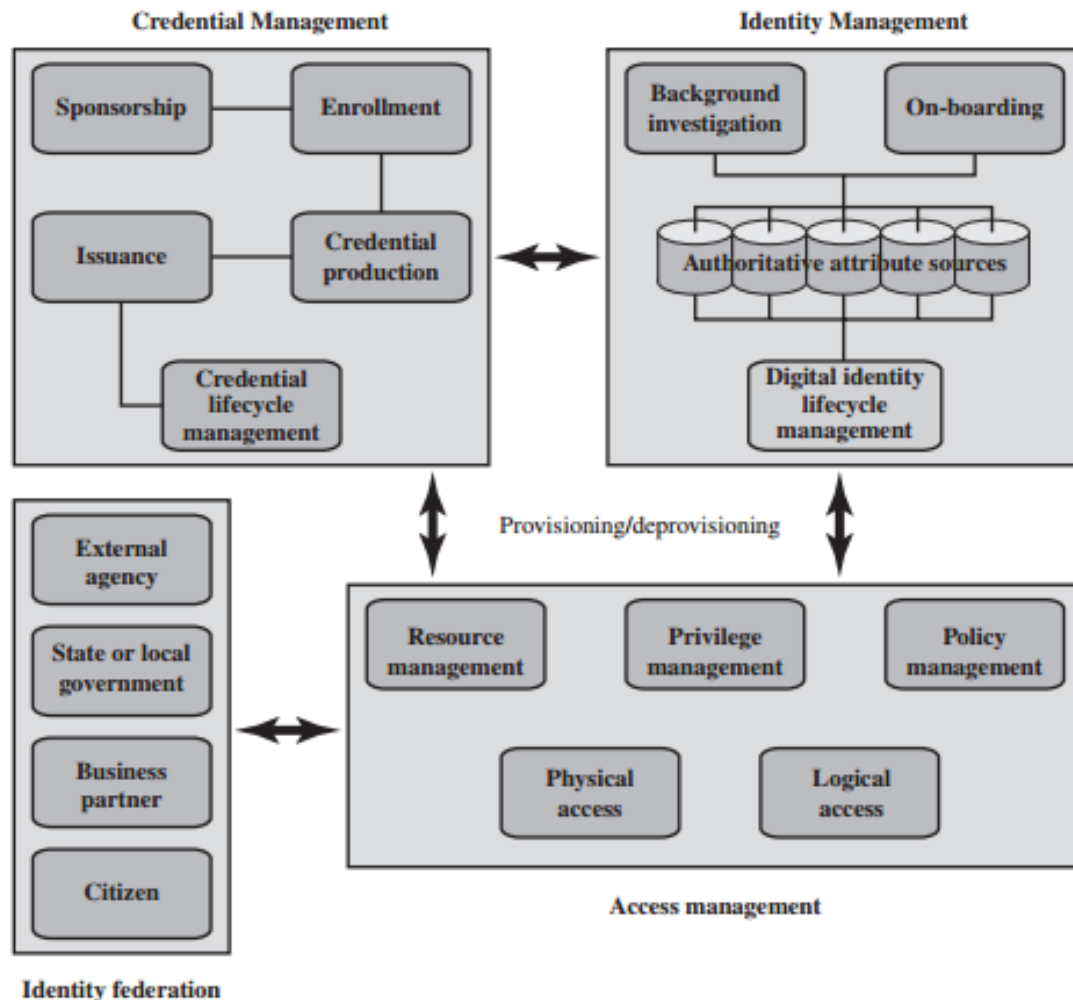


МРЕЖОВО АДМИНИСТРИРАНЕ

Access Management

Компонентът за управление на достъпа се занимава с управлението и контрола на начините, по които на единиците (субектите) се предоставя достъп до ресурси. Тя обхваща както логически, така и физически достъп и може да бъде вътрешна за система или външен елемент. Целта на управлението на достъпа е да се гарантира, че проверката на самоличността се прави правилно, когато дадено лице се опитва да получи достъп до чувствителни за сигурността сгради, компютърни системи или данни. Функцията за контрол на достъпа използва идентификационните данни, представени от тези, които искат достъп, и цифровата идентичност на заявителя.

ICAM



доц. д-р инж. Росен Радков

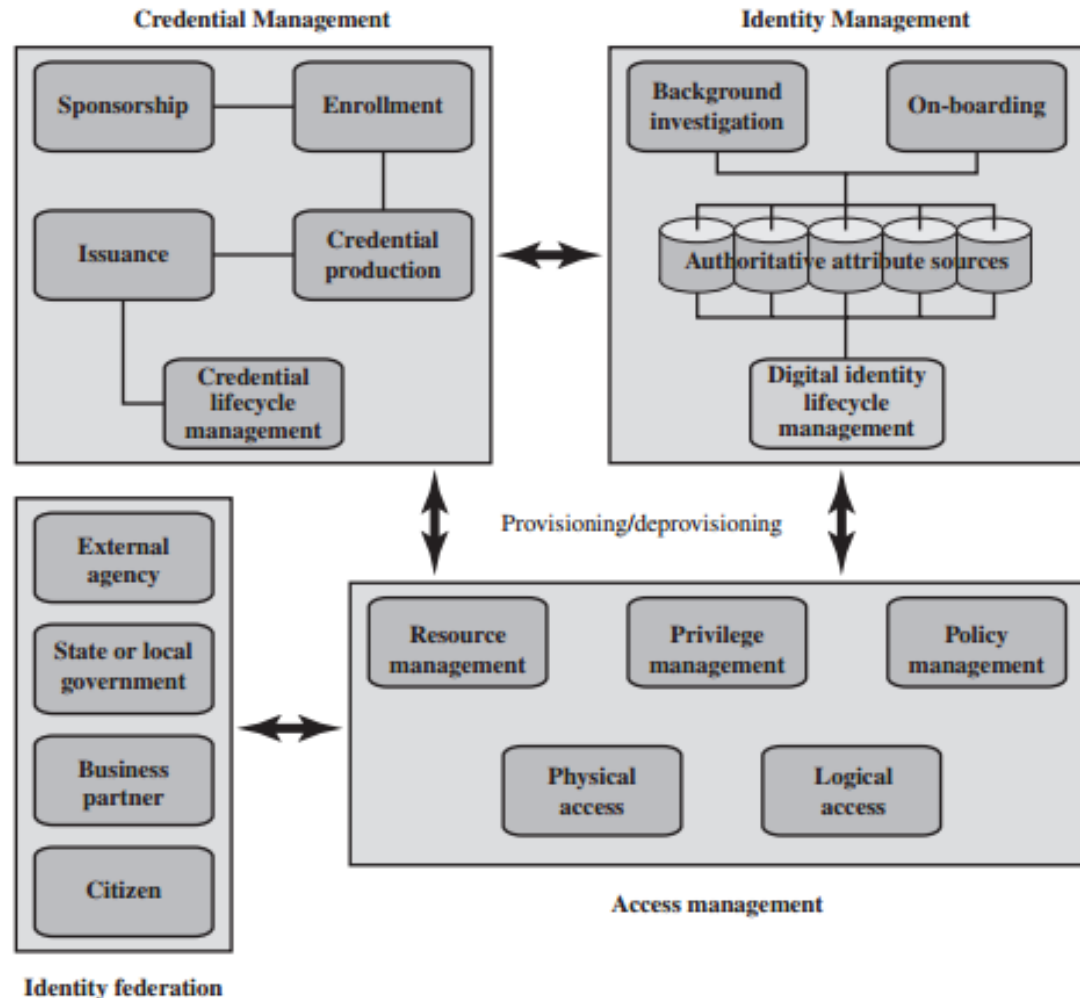
МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Access Management

- *Управление на ресурсите:*

Този елемент се занимава с дефиниране на правила за ресурс, който изисква контрол на достъпа. Правилата включват изисквания за идентификационни данни и какви потребителски атрибути, ресурсни атрибути и условия на заобикалящата среда са необходими за достъп на даден ресурс за дадена функция.



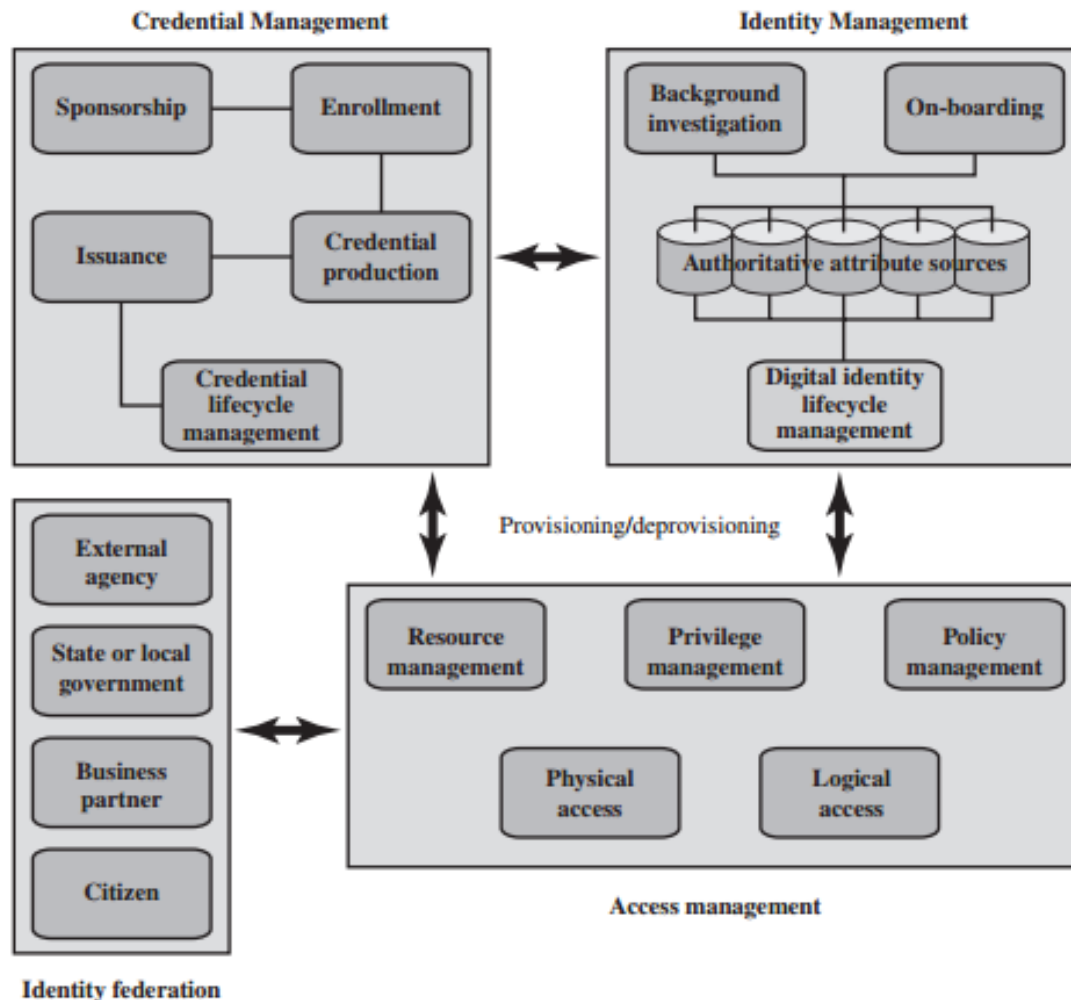
МРЕЖОВО АДМИНИСТРИРАНЕ

Access Management

ICAM

- *Управление на привилегиите:*

Този елемент се занимава с установяване и поддържане на права или атрибути на привилегии, които съставляват профила за достъп на дадено лице. Тези атрибути представляват характеристики на индивид, които могат да се използват като основа за вземане на решение за достъп до физически и логически ресурси. Привилегиите се считат за атрибути, които могат да бъдат свързани с цифрова самоличност.



доц. д-р инж. Росен Радков

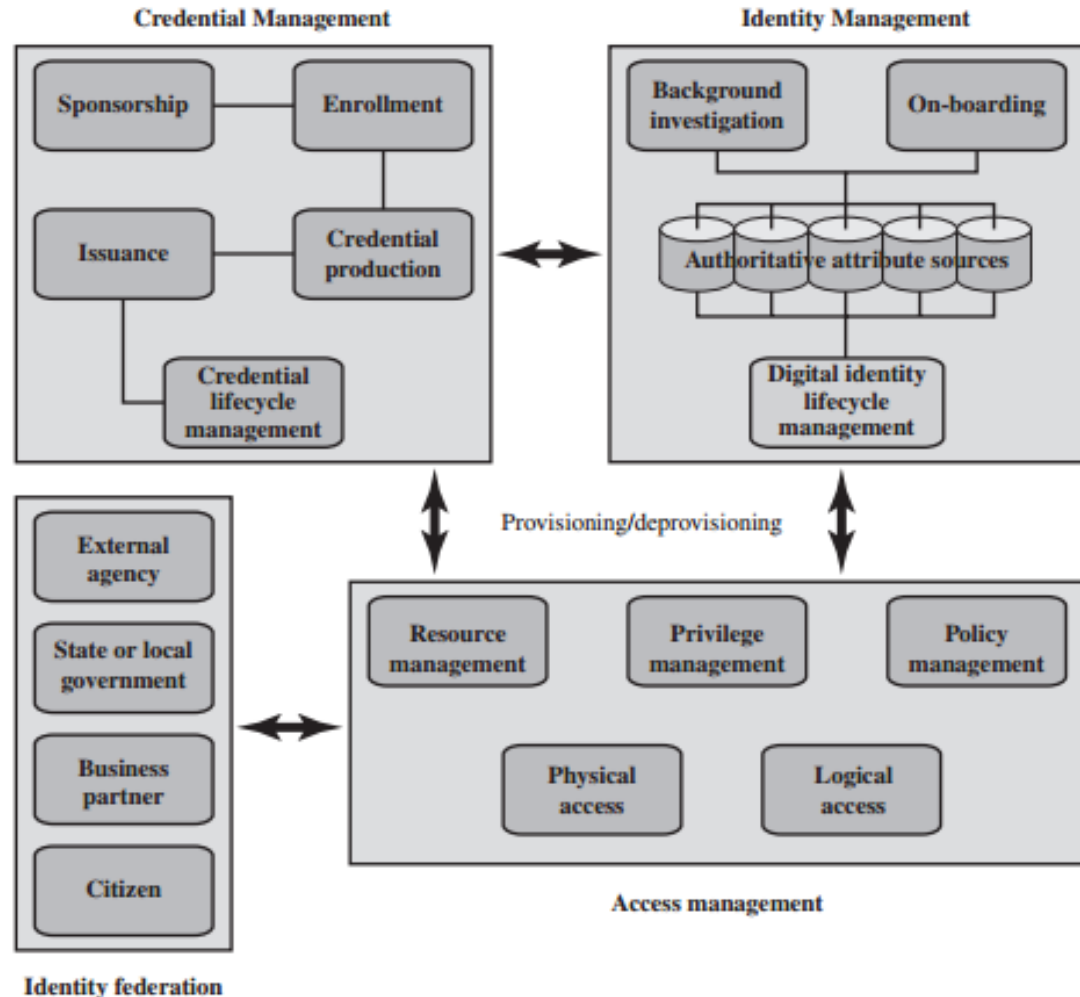
МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Access Management

- Управление на политиките:

Този елемент урежда какво е допустимо и невъзможно при транзакция за достъп. Т.е., предвид идентичността и атрибутите на заявителя, атрибутите на ресурса или обекта и условията на околната среда, дадена политика определя какви действия може да изпълни този потребител на този обект.



доц. д-р инж. Росен Радков

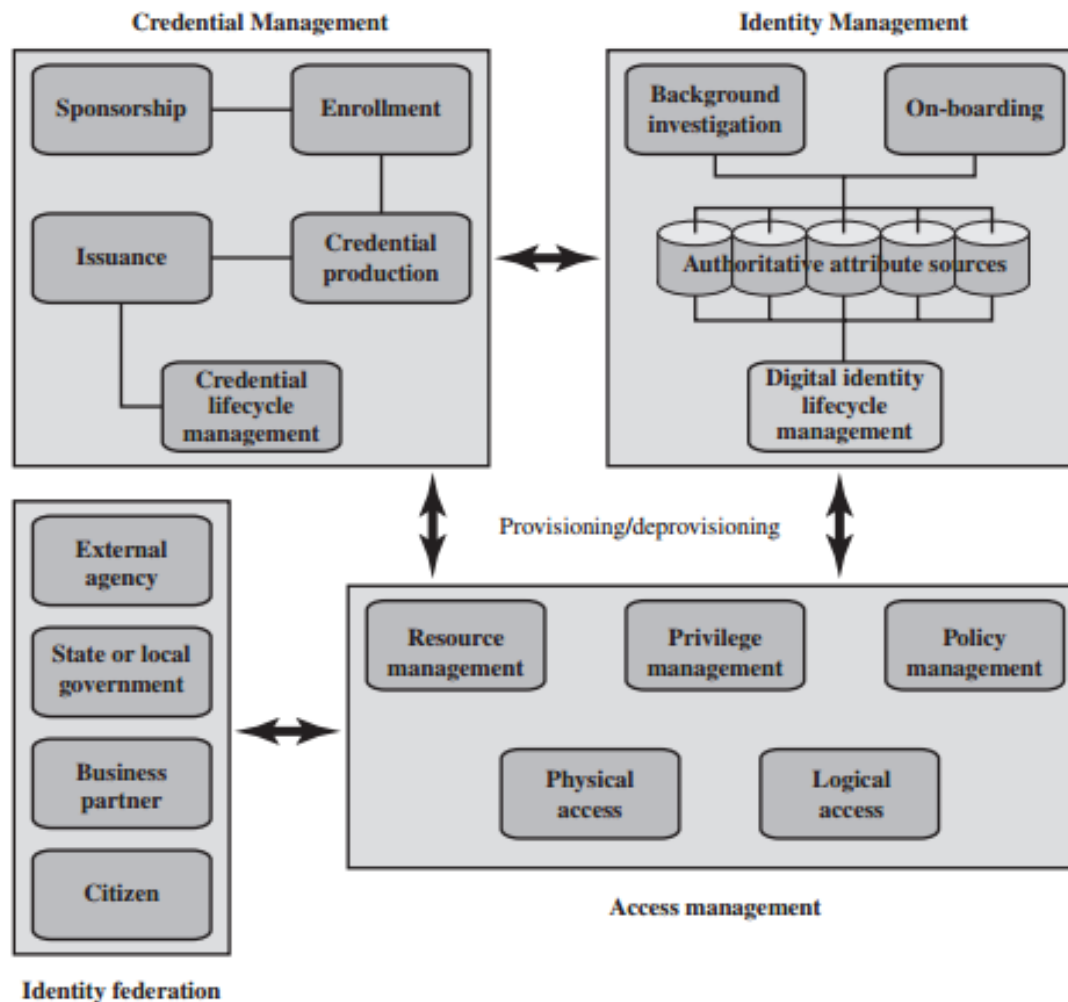
МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Identity Federation

Тя разглежда два въпроса:

1. Как да се постигне доверие на идентичностите на отделни лица от външни организации, които имат нужда от достъп до наша системи?
2. Как се гарантират идентичностите на хората от конкретна организация, когато те трябва да си сътрудничат с външни организации?



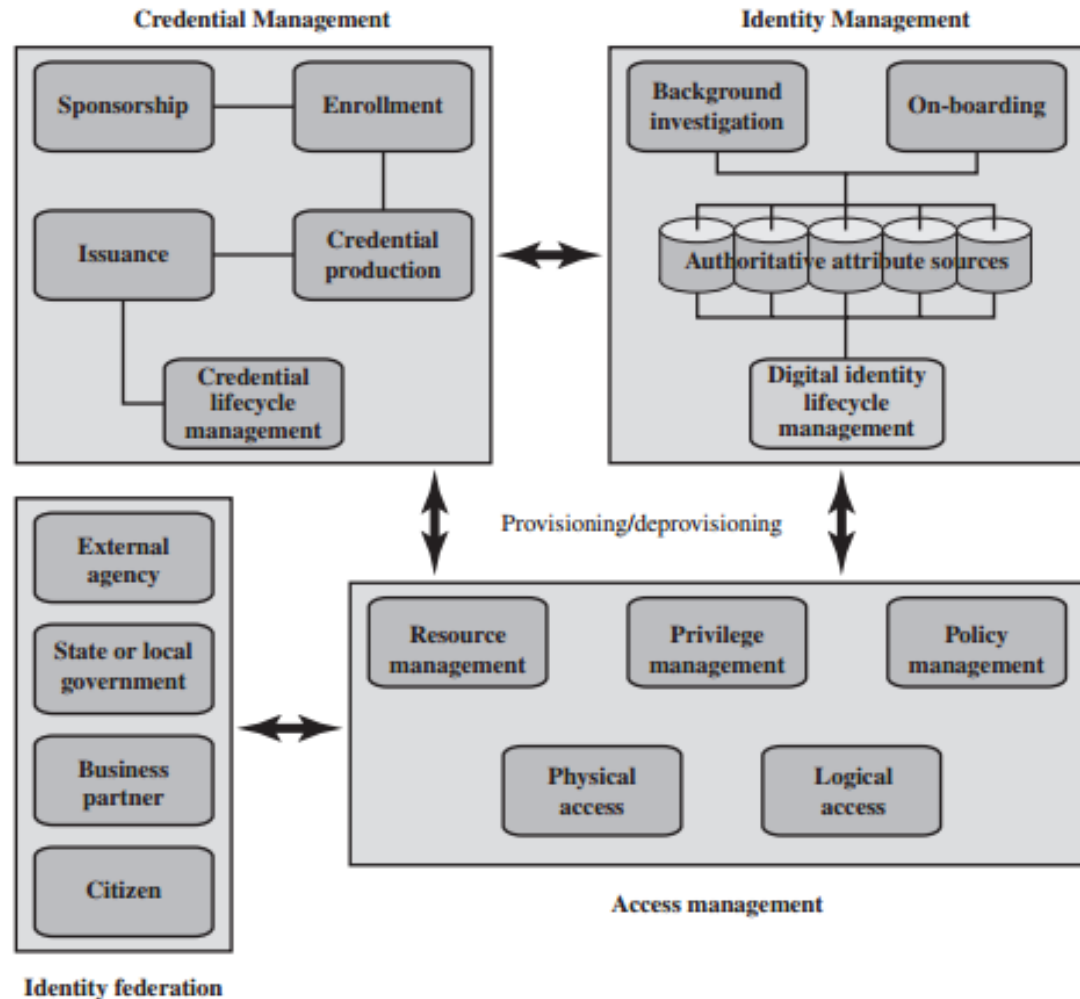
доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

ICAM

Identity Federation

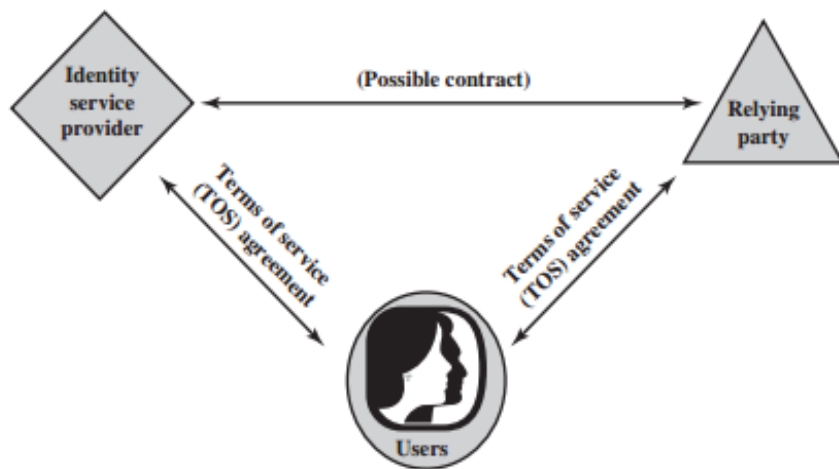
Федерацията за идентичност е термин, използван за описание на технологиите, стандартите, политиките и процесите, които позволяват на дадена организация да се доверява на цифрови идентичности, идентификационни атрибути и идентификационни данни, създадени и издадени от друга организация.



доц. д-р инж. Росен Радков

Концепция за доверие (Trust Frameworks)

Традиционен подход за обмен на идентичности



Доверяващата се страна (Relying party) изисква потребителят да е бил удостоверен до известна степен на сигурност, че атрибутите, приписани на потребителя от доставчика на услугата за идентичност, са точни и че доставчикът на услуга за идентичност е авторитетен за тези атрибути.

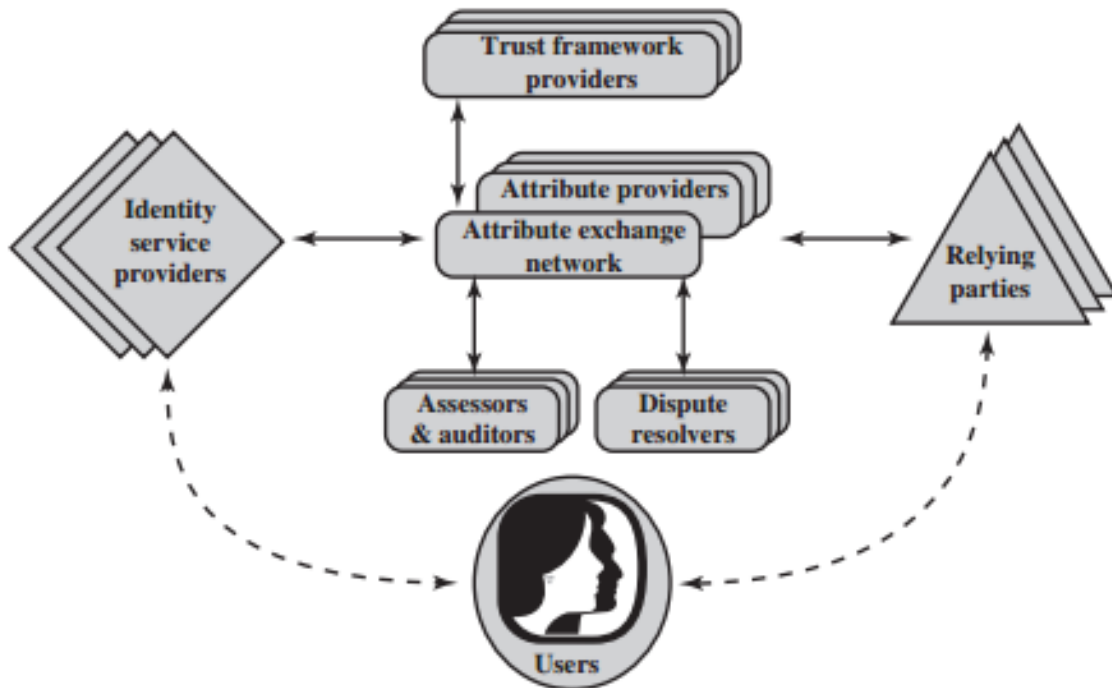
Доставчикът на услуги за идентификация изисква уверение, че разполага с точна информация за потребителя и че, ако сподели информация, доверяващата се страна ще я използва в съответствие с договорните условия и закона.

Потребителят изисква гаранции, че на доставчика на услуги за идентифициране и доверяващата се страна може да бъде поверена чувствителна информация и че те ще спазват предпочитанията на потребителя и ще зачитат поверителността на потребителя.

Най-важното е, че всички страни искат да знаят дали практиките, описани от другите страни, всъщност са тези, прилагани от страните, и колко надеждни са тези страни.

МРЕЖОВО АДМИНИСТРИРАНЕ

Концепция за доверие (Open Identity Trust Framework - OITF)



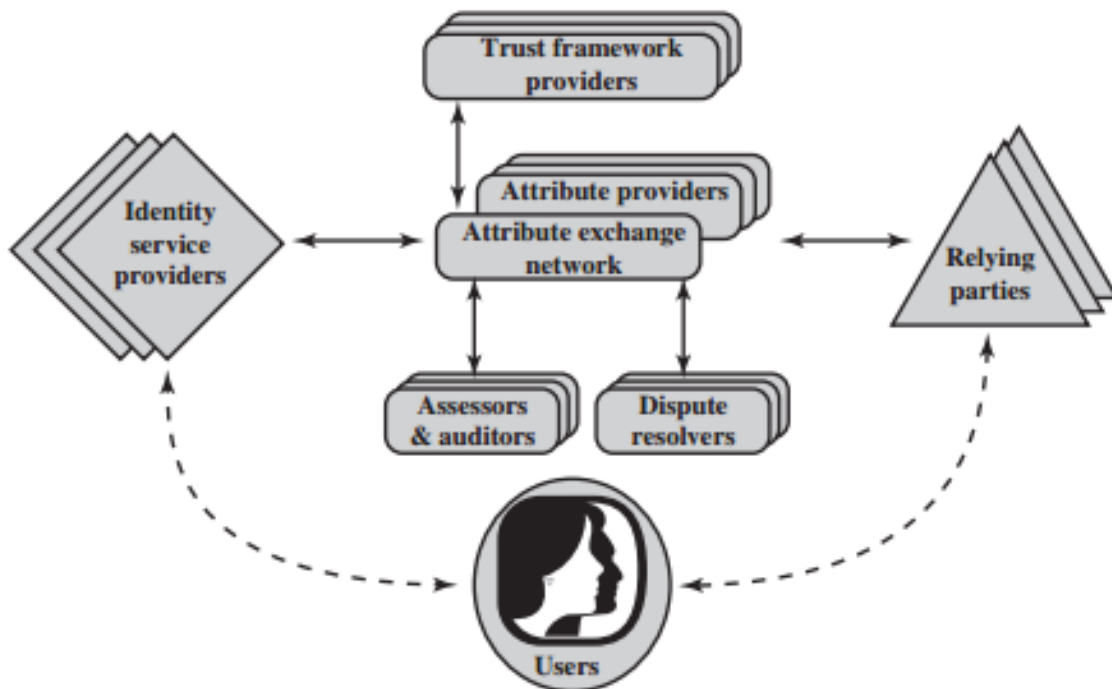
- **OIX – The Open Identity Exchange Corporation** - независим, неутрален, международен доставчик на сертифициращи рамки за доверие, съответстващи на модела OITF
- **AXN – Attribute Exchange Network** - онлайн *Internet-scale-gateway* за *IdSP* и *Relying Parties* за ефективен достъп до потребителски заявени, разрешени и проверени атрибути за самоличност онлайн в големи обеми на достъпни цени.

- **OpenID** - Това е отворен стандарт, позволяващ на потребителите да бъдат удостоверени от определени *Relying Parties* използвайки услуги от трети страни, премахвайки необходимостта уеб администраторите да предоставят свои *ad hoc* системи и да позволяват на потребителите да консолидират своите цифрови идентичности
- **OIDF** – нестопанска фондация ангажирана с предоставянето, насърчаването и защитата на OpenID технологии.
- **ICF – Information Card Foundation** е нестопанска общност от фирми и физически лица, които работят заедно, за да развият екосистемата на информационните карти.
- **OITF -The Open Identity Trust Framework**, разработена съвместно от OIDF и ICF.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Концепция за доверие (Open Identity Trust Framework - OITF)



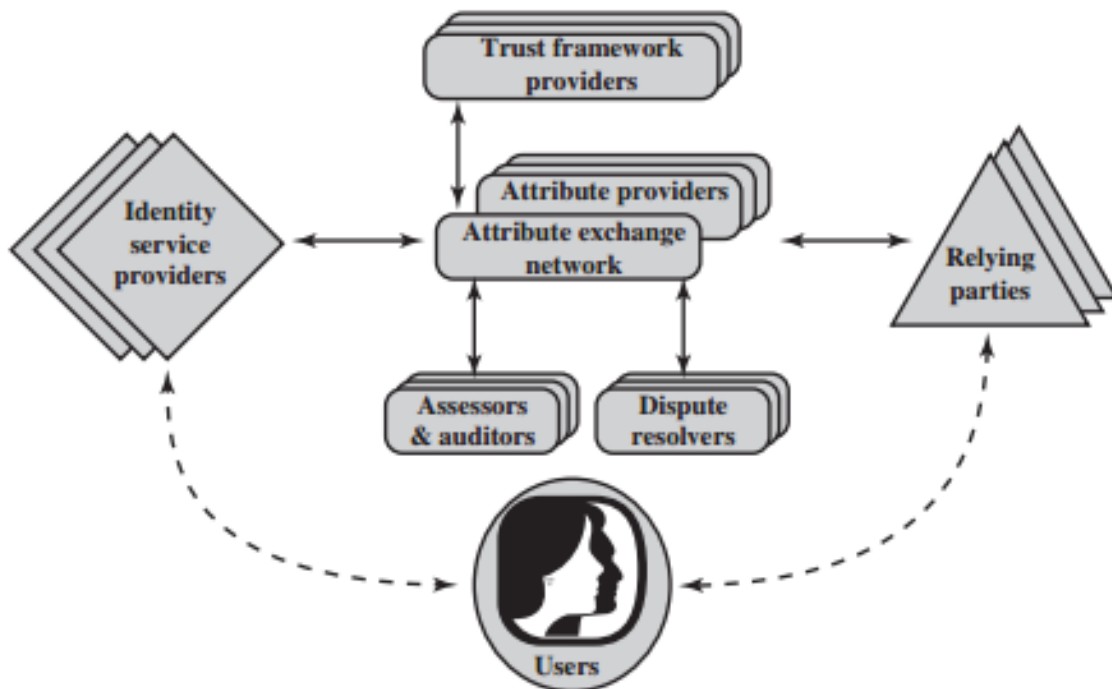
- **OIX – The Open Identity Exchange Corporation** - независим, неутрален, международен доставчик на сертифициращи рамки за доверие, съответстващи на модела OITF
- **AXN – Attribute Exchange Network** - онлайн Internet-scale-gateway за IdSP и Relying Parties за ефективен достъп до потребителски заявени, разрешени и проверени атрибути за самоличност онлайн в големи обеми на достъпни цени.

- **OpenID** - Това е отворен стандарт, позволяващ на потребителите да бъдат удостоверени от определени *Relying Parties* използвайки услуги от трети страни, премахвайки необходимостта уеб администраторите да предоставят свои *ad hoc* системи и да позволяват на потребителите да консолидират своите цифрови идентичности
- **OIDF** – нестопанска фондация ангажирана с предоставянето, насърчаването и защитата на OpenID технологии.
- **ICF – Information Card Foundation** е нестопанска общност от фирми и физически лица, които работят заедно, за да развият екосистемата на информационните карти.
- **OITF -The Open Identity Trust Framework**, разработена съвместно от OIDF и ICF.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Концепция за доверие (Open Identity Trust Framework - OITF)



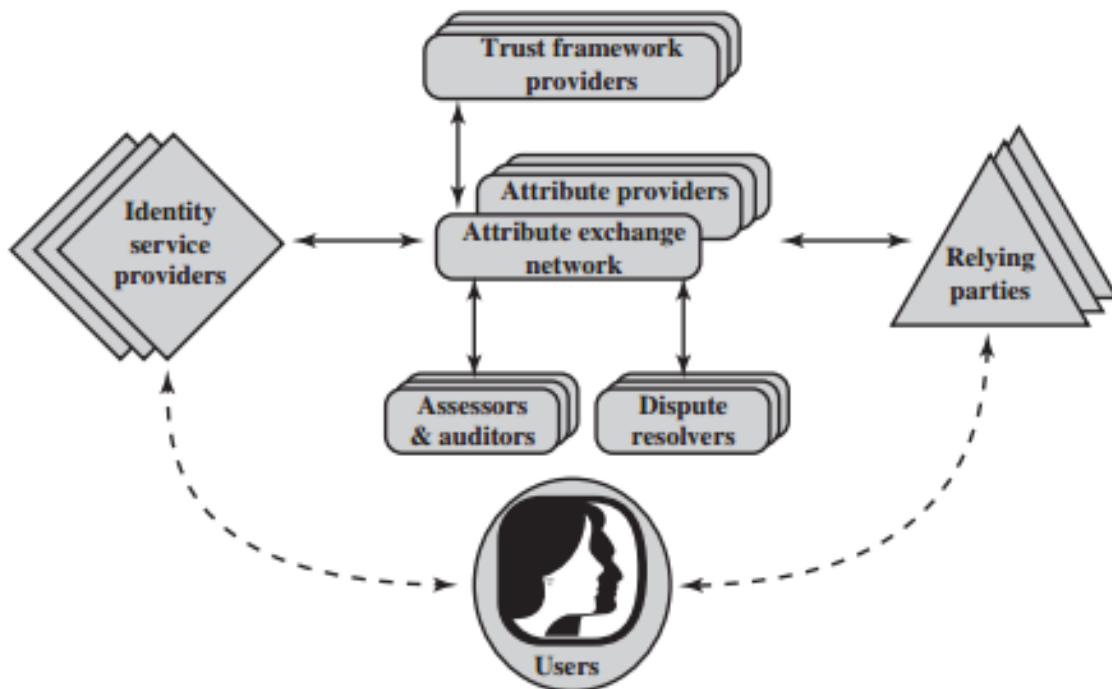
- **OIX – The Open Identity Exchange Corporation** - независим, неутрален, международен доставчик на сертифициращи рамки за доверие, съответстващи на модела OITF
- **AXN – Attribute Exchange Network** - онлайн Internet-scale-gateway за IdSP и Relying Parties за ефективен достъп до потребителски заявени, разрешени и проверени атрибути за самоличност онлайн в големи обеми на достъпни цени.

- **OpenID** - Това е отворен стандарт, позволяващ на потребителите да бъдат удостоверени от определени *Relying Parties* използвайки услуги от трети страни, премахвайки необходимостта уеб администраторите да предоставят свои *ad hoc* системи и да позволяват на потребителите да консолидират своите цифрови идентичности
- **OIDF** – нестопанска фондация ангажирана с предоставянето, насърчаването и защитата на OpenID технологии.
- **ICF – Information Card Foundation** е нестопанска общност от фирми и физически лица, които работят заедно, за да развият екосистемата на информационните карти.
- **OITF -The Open Identity Trust Framework**, разработена съвместно от OIDF и ICF.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Концепция за доверие (Open Identity Trust Framework - OITF)



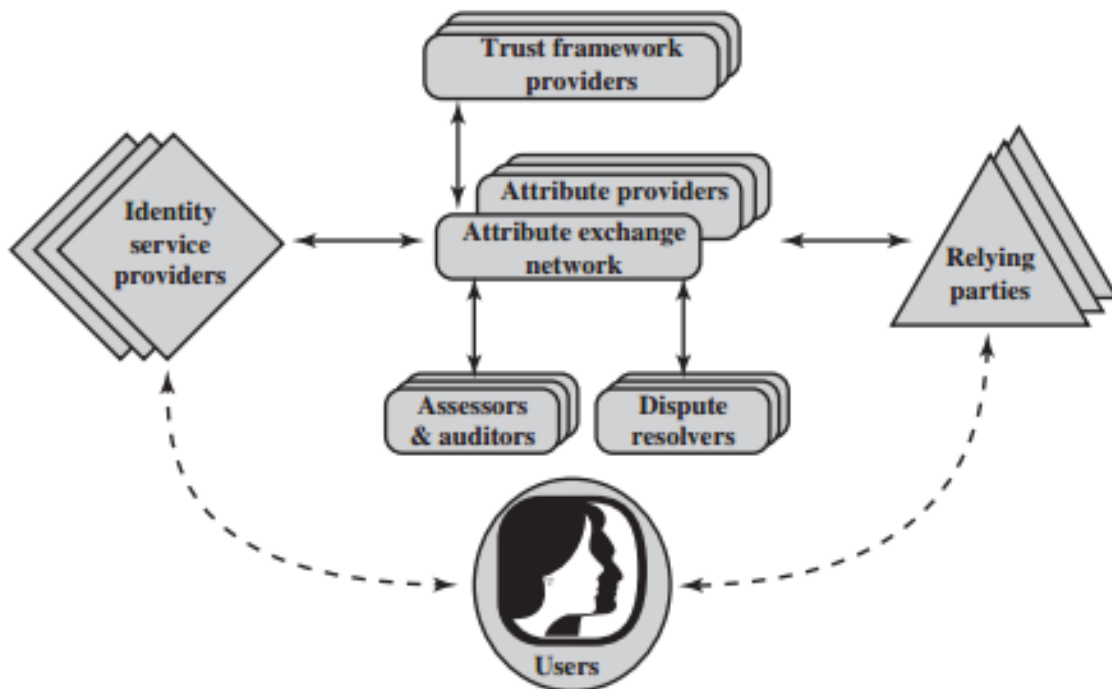
- **OIX – The Open Identity Exchange Corporation** - независим, неутрален, международен доставчик на сертифициращи рамки за доверие, съответстващи на модела OITF
- **AXN – Attribute Exchange Network** - онлайн Internet-scale-gateway за *IdSP* и *Relying Parties* за ефективен достъп до потребителски заявени, разрешени и проверени атрибути за самоличност онлайн в големи обеми на достъпни цени.

- **OpenID** - Това е отворен стандарт, позволяващ на потребителите да бъдат удостоверени от определени *Relying Parties* използвайки услуги от трети страни, премахвайки необходимостта уеб администраторите да предоставят свои *ad hoc* системи и да позволяват на потребителите да консолидират своите цифрови идентичности
- **OIDF** – нестопанска фондация ангажирана с предоставянето, насърчаването и защитата на OpenID технологии.
- **ICF – Information Card Foundation** е нестопанска общност от фирми и физически лица, които работят заедно, за да развият екосистемата на информационните карти.
- **OITF -The Open Identity Trust Framework**, разработена съвместно от OIDF и ICF.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Концепция за доверие (Open Identity Trust Framework - OITF)



- **OIX – The Open Identity Exchange Corporation** - независим, неутрален, международен доставчик на сертифициращи рамки за доверие, съответстващи на модела OITF
- **AXN – Attribute Exchange Network** - онлайн Internet-scale-gateway за *IdSP* и *Relying Parties* за ефективен достъп до потребителски заявени, разрешени и проверени атрибути за самоличност онлайн в големи обеми на достъпни цени.

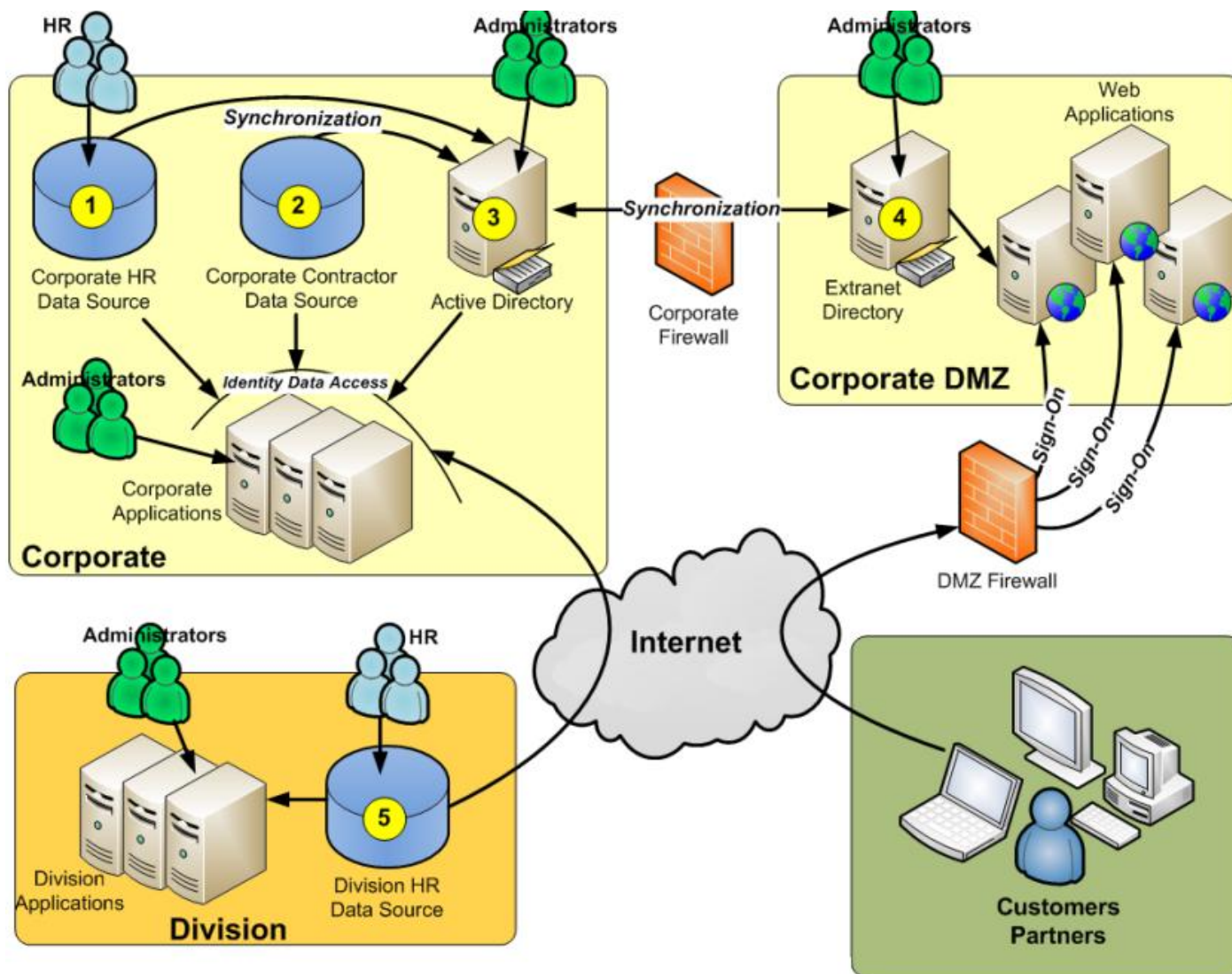
- **OpenID** - Това е отворен стандарт, позволяващ на потребителите да бъдат удостоверени от определени *Relying Parties* използвайки услуги от трети страни, премахвайки необходимостта уеб администраторите да предоставят свои *ad hoc* системи и да позволяват на потребителите да консолидират своите цифрови идентичности
- **OIDF** – нестопанска фондация ангажирана с предоставянето, насърчаването и защитата на OpenID технологии.
- **ICF – Information Card Foundation** е нестопанска общност от фирми и физически лица, които работят заедно, за да развият екосистемата на информационните карти.
- **OITF -The Open Identity Trust Framework**, разработена съвместно от OIDF и ICF.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Типична IT архитектура

- Много хранилища за ID
- Много точки за администриране
- Репликация и синхронизация в голям обем
- Потребителите трябва да се автентикират във всяко приложение

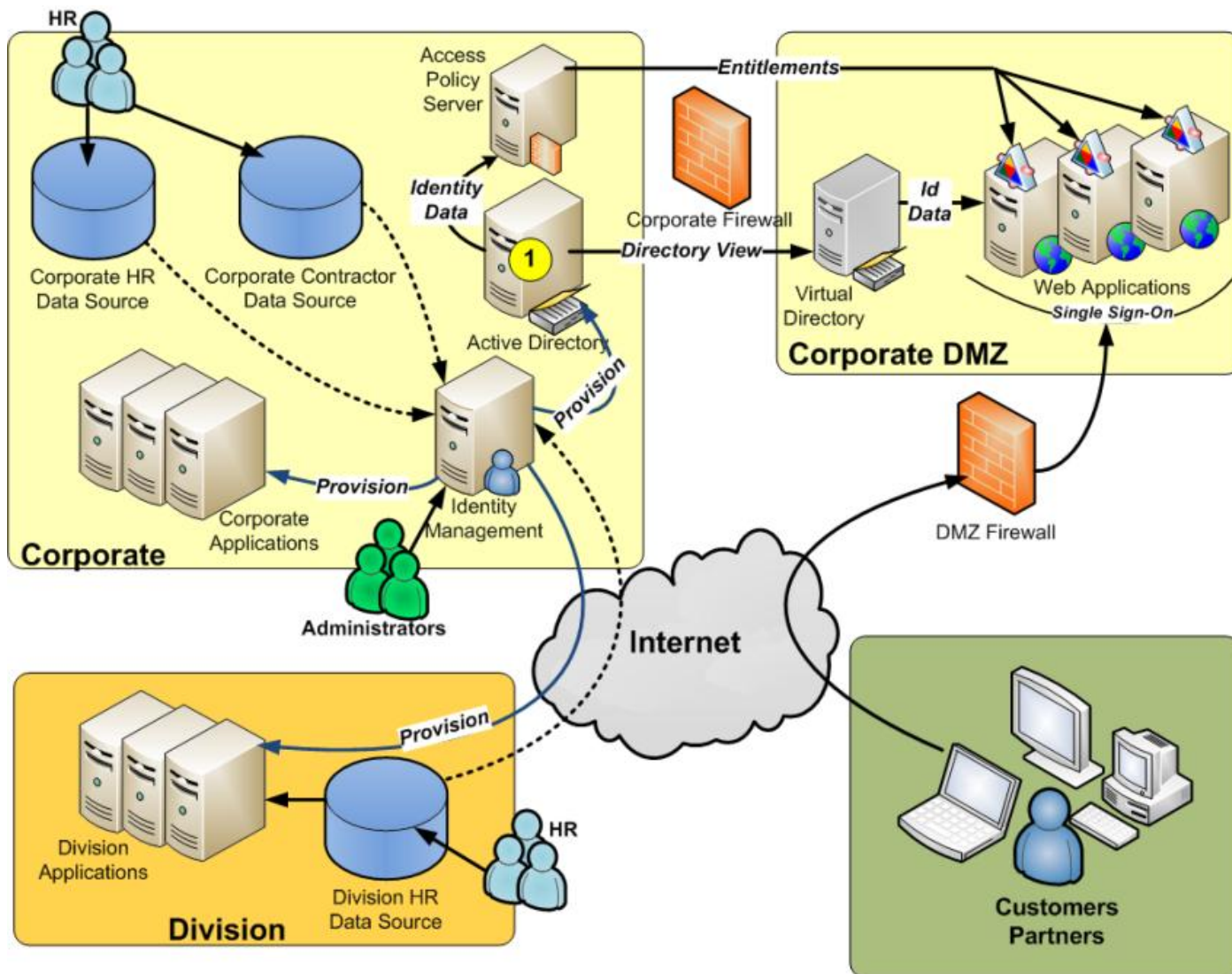


доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

I&AM архитектура

- Едно хранилище за ID
- Една точка за администриране
- Намалени репликация и синхронизация
- SSO



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за приложение на обсъжданите концепции:
Identity and Access Management in Microsoft Azure

<https://www.youtube.com/watch?v=0qZzcK1mHwA>

https://youtu.be/nRk1_koNBB8

МРЕЖОВО АДМИНИСТРИРАНЕ

БЛАГОДАРЯ ЗА ВНИМАНИЕТО!

доц. д-р инж. Росен Радков